Template for feedback to CEN 40000-1-2

Organization/individual	OpenSSF
Contacts	mneag@contractor.linuxfoundation.org; dwheeler@linuxfoundation.org
Date	8-Dec-25
Other relevant info	this is a complementary information resource to the PDF shared in a previous submission

Item number	Type of comment (editorial, technical, remark)	Comments	Proposed change
5.3.2 Guidance	technical	Regarding Section 5.3.2 (Security by design - guidance): The list of design principles as identified by Saltzer & Schroeder ("The Protection of Information in Computer Systems" <https://www.cs.virginia.edu/~evans/cs551/saltzer/>) has been foundational since the 1970s. Add points from their material that is clearly missing. It's fine to use clearer terms for their principles (there has been some change in terminology since then), but they should not be omitted. Currently this section covers several, and "secure by default" is broadened and changed into a separate point, but it's still missing some points.	Please add these points from S&S: Strive for simplicity ("economy of mechanism"). Unnecessarily complex systems are harder to review and to keep secure. Non-bypassability ("complete mediation"). Every untrusted request must be checked for authority by a trustworthy component. For example, many security checks must be in server-side software and not in web browsers, mobile applications, or clients, because an attacker might routinely have control over the latter. Maximize ease of use ("psychological acceptability"). The human interface must be designed for ease of use, so that users "routinely and automatically" apply the mechanisms correctly. This also reduces mistakes because the user understands what the system is doing.
5.3.2 Guidance	technical	Additional feedback to the section 5.3.2	In addition, we think these principles would be valuable to include: Make changes securely: ensure that updates do not compromise the security of the service. Design flexible architectures: Develop digital services and modernize legacy components to enable smoother integration of new security controls as business needs, cyber threats, and vulnerabilities evolve. Leverage existing components: This principle emphasizes minimizing the attack surface by reusing established software components rather than introducing new, untested code. Source secure third party products: Ensure the security of third-party products by continuously evaluating the platforms, software, and code they provide, addressing any identified risks and collaborating with suppliers to strengthen their security posture. Prefer well-vetted, secure components, whether closed or open source, to maintain strong protection in software products. When using open-source technologies, take responsibility for reviewing packages, contributing improvements, and supporting the ongoing maintenance of critical dependencies. (Sources: https://www.security.gov.uk/policy-and-guidance/secure-by-design/principles/ and https://devguide.owasp.org/en/02-foundations/03-security-principles/)
5.4.2 Guidance	technical	We would like to expand this phrase "This is done by minimizing the attack surface of a product, ensuring that secure configurätions are the default, and informing the users about the default secure state."	This is done by implementing tactics like: eliminating the default passwords implementing Multi-Factor Authentication use Single Sign-On mechanisms based on open standards providing secure logging without further additional configuration Creating Software Authorization Profiles and their designated use cases Tracking and reducing 'hardening guide' size Prioritizing the security over backwards compatibility. Source "https://www.cisa.gov/sites/default/files/2023-10/SecureByDesign_1025_508c.pdf"
5.5.2 Guidance	technical	In the list started after "Transparency includes amongst others, methods of relaying information related to:"	we would like to add another topic in that list "- third-party software components used"

6.1 General	editorial	update "reviewing management of the risks according"	include monitoring also in this. The last bullet should be "monitoring and reviewing management of the risks according to 6.7" that will provide also an alignment with the figure from below
6.1 General	technical	update figure 1 and the phases of risk assessment	we would like to add also add risk identification in the risk assessment phase
6.2.1.2 Product intended purpose and reasonable foreseeable use	editorial	some gramatical errors and unclarity in the "Intended purpose: to controls physical access to residential and office premises via a smartphone application and digital key management. Reasonably foreseeable use:"	replace with: "Its intended purpose is to control physical access to residential and office premises via a smartphone application and digital key management. Its Reasonably foreseeable use can be described through the next actions:"
6.2.1.6 Product user description	editorial	The phrase "The product's end user, also referred to in this document as user, is any natural or legal person intended to install/operate/handle/use." is missing a pronoun or a noun	add 'the product' or 'it' at the end of the phrase
6.2.1.6 Product user description	technical	referring to the "install/operate/handle/use" phases from this chapter	add update/upgrade?
6.2.2 Input	editorial	why 'existing' in "existing product architecture"? we would propose to remove it	remove the term 'existing'
6.2.3 Requirement	technical	regarding the phrase "It is recommended to align with the terminology used in the blue guide to describe the product user."	We would remove that line from this section and detail it in 6.2.1.6.
6.3.1 General	technical	regarding the phrase "whether appropriate risk treatment has been applied, and whether the residual risk is acceptable or further mitigation is required." How can this be true in the step number 2 of this process? should not be the risk identified prior to establishing such things?	please justify that step in this phase
6.3.1 General	editorial	in the first phrase of the Note 1 the subject is missing	add 'an analysis is done…"
6.3.1 General	technical	in the note 4 we do not understand wht 'state of art' is meaning	this is a very subjective term. Moreover is not defined anywhere in the document. We would prefer to have this note removed.
6.3.3 Requirement	editorial	correct 'measure'	measured' is the correct version there
6.3.3 Requirement	editorial	replace 'defined'	we have two times defined in 10 words. The second defined can be replaced by 'created'
6.3.3 Requirement	technical	The bullet 'Aligned with the state of the art and current values of society for the product;' does not make any sense	we propose to remove that bullet
6.3.3 Requirement	technical	As for the one from above - we do not understand the meaning of the 'state of the art and current values of society.'	we propose to remove that also
6.3.5 Assessment criteria	editorial	In the phrase "there is evidence that he applied risk assessment and treatment methodology applied to the product meets the requirements." there is a grammatical error	replace 'he' with 'the'
6.3.5 Assessment criteria	editorial	In the phrase "there is evidence that he applied risk assessment and treatment methodology applied to the product meets the requirements." the word 'applied' is repeated twice	we propose to remove the first occurrence of the term 'applied'
6.4.1 General	technical	phrase "The risk assessment is based on the products' context and the risk assessment results in an evaluation of identified risks." is not well built	how the risk assessment be based on the risk assessment results?
6.4.1 General	editorial	The phrase "As long as the risk estimation is based on the likelihood of occurrence or exploitability and the magnitude of loss or disruption after a successful attack." from the Note 3 is incomplete	Append ", it is acceptable."
6.4.2.5 Assessment criteria	technical	Assess whether assets and cybersecurity objectives from 6.4.2.4 is complete.	there is no criteria to define the completeness of those objectives.
6.4.3.1 General	editorial	Regarding "it is now possible to determine the threats to the product."	Change "it is now possible to determine the threats to the product" to "it is now possible to use a structured approach to determine the potential security issues in the product". The first sentence in the paragraph defined the term "threat modelling". Do not redefine the term "threat modeling" with a different meaning in the next sentence, especially one using a highly ambiguous and undefined term like "threat"; instead use the definition just given.

6.4.3.1 General	technical	"Threat modelling is a structured approach for identifying threats."	Delete this sentence “Threat modelling is a structured approach for identifying threats.” You already defined the term “threat modeling” (don’t redefine it), and the term “structured approach” belongs earlier. In addition, avoid using the word “threat” by itself in this document. The term “threat” is a notoriously ambiguous word when by itself. People may understand “threat” as an event, a weakness, a vulnerability, a threat actor, or something else. Official documents use this word in all these ways! I recommend completely avoiding the word “threat” by itself unless it’s part of a compound phrase like “threat modeling” or “threat actor”. That way, people will have a chance of having a shared understanding of what you mean.
6.4.3.1 General	technical	why we are talking about threat modelling so extensively in a chapter dedicated to the threat identification?	Those two notions are different. From the definition from the NIST, I understand that we are talking about two different things. The thread modelling is defined as: “A form of risk assessment that models aspects of the attack and defense sides of a logical entity, such as a piece of data, an application, a host, a system, or an environment.” To my understanding, threat identification is just a part of the threat modelling: https://owasp.org/www-community/Threat_Modeling
6.4.3.2 Input	technical	"the product context from 6.2" is not complete	After “the product context from 6.2” insert “especially the product architecture overview from 6.2.1.5”. That’s a primary input, so it’s important emphasis it.
6.4.3.2 Input	technical	"relevant known exploitable vulnerabilities." is too general	This doesn’t give any indication of what a “relevant” known exploitable vulnerability (KEV) would be. As written it’d be too easy to ignore relevant ones. Append before the period “, including current and previous product versions, components used by the product, and similar products”
6.4.3.3 Requirement	technical	Update the term 'Threats'	Change “Threats” to “Potential security issues”. This current text is incompatible with section 6.4.3.1, which says that “Threat modelling is a security design analysis technique that identifies potential security issues”. The word “threat” in isolation has so many meanings that when it’s by itself it’s better to replace it with a different term.
6.4.3.4 Output	technical	update the "a list containing the threats for each asset."	Replace “a list containing the threats for each asset” with “a list of each potential security issue”. The current text is incompatible with section 6.4.3.1, which says that “Threat modelling is a security design analysis technique that identifies potential security issues”. Use the definition given, not “threat” which is a highly ambiguous word when unpaired with another word. Similarly, throughout the document, replace the word “threat” whenever used in isolation with a clearer definition. Also, we do NOT want for each asset; typically we want groupings by importance, not by the asset (organizations sometimes struggle to identify assets; we want vulnerabilities identified even when it’s not clear which assets will be affected).
6.4.3.5 Assessment criteria	technical	Replace "a list of threats exists for each asset."	Replace “a list of threats exists for each asset” with “a list of potential security issues”. The term “threat” is not used in the definition of section 6.4.3.1. Same throughout. Replace “threat” with “potential security issue” here & throughout when not part of a compound word.
6.4.3.5 Assessment criteria	technical	What 'is sufficient' means?	What does sufficient mean in "Assess whether the list of threats for each asset from 6.4.3.4 is sufficient."?
6.4.5.3 Requirement	editorial	Grammar mistake: "ujstificätion"	replace it with "Justification"
6.5.1.1 Aim of risk treatment	technical	update "The aim of risk treatment is to reduce or mitigate risks so that the residual risk is acceptable."	In section 6.5.1.1, change “to reduce or mitigate risk” into “to sufficiently avoid or mitigate risk”. There is no “reduce” option in section 6.5.1.6, the term is “mitigate”. It’s also likely that the intended meaning of the word “reduce” here is a synonym, and thus the “or” is nonsensical. Finally, avoid is an option, we should encourage avoiding risk where it’s reasonable to do so.
6.6.1 General	editorial	Update "Where appropriately this communication considers accessibility aspects (e.g. simple language, multi-modal formats)."	“Where appropriately” should be “Where appropriate”

6.6.1 General	technical	there is a repetition between 6.6.1 and 6.6.3 6.6.1. "Where appropriately this communication considers accessibility aspects (e.g. simple language, multi-modal formats)." 6.6.3."Where appropriate, the communication with the affected stakeholder shall consider accessibility aspects (e.g. simple language, multi-modal formats) for each stakeholder."	delete one of the occurences
6.6.3 Requirement	technical	In the Note 1 "Where relevant to the CRA [1] this information can be added to the information and instructions to the user." what is the meaning of " where relevant to the CRA"? Is not everything relevant for CRA?	remove this note
6.6.3 Requirement	editorial	In the Note 1 "Where relevant to the CRA [1] this information can be added to the information and instructions to the user." there is a bad formulation "this information can be added to the information"	if this note is not removed, please try to revise this fomulation
6.7.3 Requirement	editorial	in the note "NOTE This document cannot specify the regularity with which to monitor or review. Context specific information is needed to specify this information." the last phrase does not make sense	remove "Context specific information is needed to specify this information."
7.1 General	technical	the overall form of chapter 7	Section 7 (ALL) “Cybersecurity activities” - As written, the entirety of section 7 seems to dangerously presuppose that cybersecurity activities occur in vacuum, unrelated to and independent of product lifecycle activities (including development). For example, the current text appears to presume there is a “secure implementation” activity that is separate from and unrelated to the product implementation activity. Some of these cybersecurity-specific activities might be performed by different personnel or at different times from the “main” parent activities, but they MUST NOT be siloed activities to be ignored and discarded by the people doing the “real work”. Instead, this section must make clear that these cybersecurity activities are part of the activities of the product lifecycle and MUST be integrated into the normal lifecycle activities. We propose fixing this by appending a new paragraph in section 7.1 with this text: All of the activities described in this section are by definition subactivities of their corresponding system lifecycle activities. For example, the activity “secure implementation” MUST be a part of implementation and MUST NOT be a separate activity unrelated to implementation. Activities described in this section may be performed by specialists and/or in facilities separate from others performing the larger system lifecycle activities, but the activities described here MUST be part of the overall system lifecycle activities where performed. They MUST NOT be separate unrelated activities which lack access to necessary input or whose outputs are ignored.
7.2.3 Requirement	technical	regarding "— vulnerability response planning (e.g. typical timescales for vulnerability handling)."	this should not be required as the CRA defines these timescales
7.3.1 General	technical	Imprecise formulation in "NOTE 1 In line with ISO/IEC terminology, “requirements” in this document can express obligations, permissions, or prohibitions. They define what is expected. “Controls” (sometimes also referred to as safeguards) are the measures implemented to fulfil those requirements."	change “fulfil those requirements” to “fulfil some of those requirements”. Not all requirements require a control.
7.3.2 Input	technical	"— applicable state of the art." - who defines if it is applicable or not? and, again, what is state of the art?	please remove this line
7.4.3 Requirement	technical	"In case the product contains third-party components or RDPS as identified in the product context, due diligence shall be applied to all components, whether third-party or not, and to their integration." it's already mentioned above that third party component integration is performed with due diligence. Moreover this phrase is not going well. We are having difficulties in understanding it.	We would prefer to remove it
7.5.1 General	technical	"Managing dependencies and third-party libraries by selecting secure libraries and keeping them up to date." - this may not be the full responsibility of the manufacturer. it can contribute to maintain them up to date but it's not entirely its responsibility	please remove "keeping them up to date"

7.5.3 Requirement	technical	imprecise formulation: "SBOM appropriate for the product;". how to define the 'appropriateness' of an SBOM for a product?	We would prefer the PT3 approach encouraging the manufacturers to create that SBOM as deep as they can and in accordance with the criticality of the product
7.5.4 Output	technical	One of the outputs requested is "an SBOM;". what kind of SBOM? what it should include?	could you please be more precise? The concept from CRA could be copied here also: an SBOM containing at least the top-level components
7.6.1 General	editorial	In the paragraph "Cybersecurity V&V often includes but are not limited to the following approaches:" should not we have a 'testing' main bullet and all those being sub-bullets? We see a lot of word 'testing' too much	Have a 'testing' main bullet and multiple sub-bullets reflecting the already existing bullets
7.8.3 Requirement	editorial	why have two phrases here? "Potential cybersecurity issues shall be identified. Potential cybersecurity issues shall be assessed."	replace it with "Potential cybersecurity issues shall be identified and assessed."
7.9 Product monitoring	technical	the title is very confusing wrt to the content of this chapter.	We would propose "Monitoring the threat landscape of a product"
7.9.1 General	editorial	NOTE 3 Monitoring can include monitoring of vulnerability databases, and other sources of vulnerability reports, either manually or through automated means. - it does not sound very well	We would propose using "This phase can include monitoring....."
7.9.4 Output	technical	Would "cybersecurity related issues identified during the product lifecycle of the product are monitored." meaning that any manufacturer should follow all the vulnerability databases continuously?	If so, that is not feasible for SMEs
7.11.1 General	editorial	"evaluating that the third-party component is compliant with applicable legal and contractual requirements and the cybersecurity requirements in particular for the product. This can be done by, amongst others, checking for:" what is the purpose of the 'in particular' there?	We would remove the 'in particular' from there
7.11.1 General	editorial	"availability of regular cybersecurity patches;" is overlapping with "considering the support period of components when selecting them for integrating these into the product. This anticipates the risks arising from deprecated third-party component and obsolete technologies;"	remove the "availability of regular cybersecurity patches;"
7.11.1 General	editorial	"a risk assessment;" is overlapping with "assessing the risk of the third-party component and its integration in the risk assessment of 6.4;"	remove the "a risk assessment"
7.11.1 General	technical	"communicate newly found vulnerabilities in the third-party component as well as sharing potential solutions if available."	replace the 'sharing' with 'sharing with the community the'
7.11.1 General	technical	use of 'open source stewards' in that text. Open source stewards are not responsible third parties for any third-party software integrated into the final PDEs.	Replace 'open source stewards' with 'open-source maintainers'
7.11.1 General	technical	"To support a culture of transparency and collective cybersecurity improvement, manufacturers may share with the third-party any developed fixes for vulnerabilities found in the supplier's component."	Replace 'may' with 'shall' as it is a legal obligation
7.11.3 Requirement	technical	"Due diligence shall be applied to the selection of the third-party components." how is the 'selection' defined? what is the connection with the creation of SBOMs for top-level dependencies?	selection only for top level components?
7.11.3 Requirement	technical	"The selection of the third-party components shall be justified and documented." - what means justified here?	Remove 'justified'
7.11.3 Requirement	technical	"Third-party software components shall be added to the SBOM to manage dependencies in accordance with 7.5;"	that is mandatory only for the top-level dependencies, right? Otherwise this is a misalignment with the requirements for SBOMs from the legal document
7.11.3 Requirement	technical	"remediated according to the vulnerability disclosure and handling procedures."	Add "Remediations shall be also shared with the third-party entities"
Annex B	technical	The whole Annex	this is very much against FOSS licensing approach: "no warranties, no liabilities" We are not sure if all the small FOSS projects will adhere to this and imagine the whole burden for a manufacturer to search all the maintainers of their third-party integrated software to fill such paper
Annex B	technical	"This annex provides an example of a Cybersecurity Supplier Agreement (CSSA) between the manufacturer and third-party providers (suppliers) of components or services, mainly applicable in a business-to-business context."	The example is fine for the intended context, but the earlier text is likely to mislead readers into thinking it's acceptable in cases that this example is NOT intended for. Modify "mainly applicable in a business-to-business context" to say "applicable in a business-to-business context with a commercial third-party component. This example would be inappropriate for a non-commercial open source component and should not be used in such cases."

Table B.1 — Example of a CSSA	technical	this is very wrong. OSS Suppliers have no legal obligations under CRA. They should not be responsible for anything. Pushing potential liability upstream to developers was intentionally negotiated out of the CRA and should not be introduced indirectly via contracts.	remove that table
D.6 Recommended solution to ensure maximum cybersecurity to the potential users	technical	"These changes will not impact the cybersecurity of the product."	Change “will not impact” to “do not need to impact”. Some changes definitely CAN weaken cybersecurity, but they do not NEED to do so.